

MULTIMEDIA UNIVERSITY, MALAYSIA

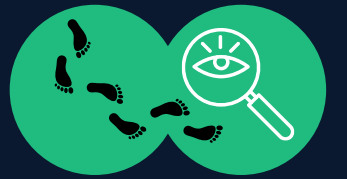
Footprinting and Reconnaissance

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain

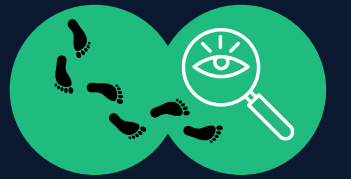


DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

Learning Objectives



What You Will Learn?

- The reconnaissance phase in penetration testing
- Differentiate between passive and active footprinting
- Apply various information-gathering techniques
- Use OSINT tools effectively
- Identify DNS vulnerabilities, including zone transfers
- Understand basic social engineering concepts in reconnaissance

“

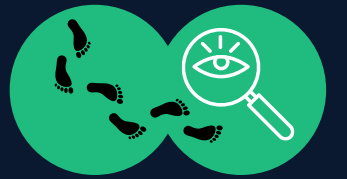
Give me six hours to chop down a tree and I will spend the first four sharpening the axe.”

– Abraham Lincoln

In pentesting: Spend 80% of time in reconnaissance!

Learning Outcomes: By the end of this lecture, you will understand the reconnaissance phase in penetration testing, OSINT tools, DNS vulnerabilities, and social engineering concepts.

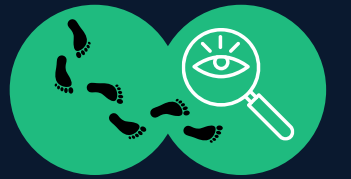
Introduction



- **Reconnaissance:** Gathering information from public websites, social media, and internal networks to identify vulnerabilities.
- **Footprinting:** The process of gathering information about a target system or organization to identify potential vulnerabilities.
- **Social Engineering:** Manipulating individuals into divulging confidential information or performing actions that compromise security.

Overall: These techniques are foundational in ethical hacking and penetration testing.

What is Reconnaissance?



Reconnaissance (Recon): It is the first phase of penetration testing, saying that the systematic process of gathering information about a target system, network, or organization before launching an attack without directly interacting with it.

Why is Reconnaissance Critical?

- **Foundation for all attacks:** Better information = better targeting
- **Identify attack surface:** Find all possible entry points
- **Reduce detection risk:** Avoid noisy, unnecessary scans
- **Plan attack strategy:** Choose the right tools and techniques
- **Save time:** Focus on actual vulnerabilities

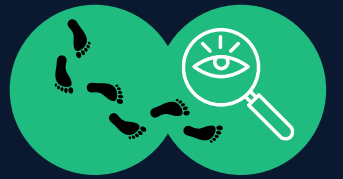
Real-World Analogy:

 Like a **thief** studying a building's layout, security systems, and schedules before attempting a break-in.

 **Chess player:** Studies opponent's strategy.

 **Military:** Gathers intel before attack.

Types of Recon



Three Main Categories

1. Social Reconnaissance

- Gathering information through social media platforms
- Monitoring employee posts and activities
- Identifying organizational relationships
- Example: LinkedIn for employee roles, Facebook for personal details

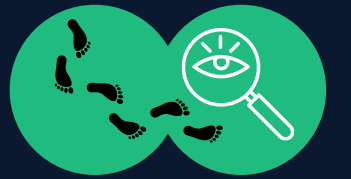
2. Public Reconnaissance

- Using publicly available information
- Company websites, news articles, press releases
- Public databases and records
- Example: Company website revealing technology partners

3. Software/Technical Reconnaissance

- Using technical tools and methods
- Network scanning, DNS queries, port scanning
- Example: Using Nmap to identify open ports

What is Footprinting?



The Foundation of Reconnaissance

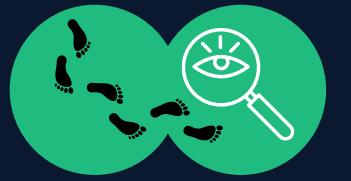
Footprinting: Collecting information about a target to create a comprehensive profile or "footprint."

What attackers look for:

- Network architecture and topology
- Domain and subdomain information
- IP address ranges
- Employee information
- Technology stack (operating systems, applications)
- Security mechanisms in place
- Physical location details

Outcome: A detailed blueprint of the target environment.

Passive Footprinting - Overview



Non-Intrusive Information Gathering

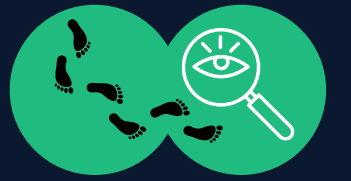
Characteristics:

- Completely legal when using public sources
- No logs left on target systems
- Can be performed anonymously
- Time-consuming but safe

Primary Sources:

- Search engines (Google, Bing)
- Social media platforms
- Public databases (WHOIS, DNS records)
- Company websites and documents
- Job postings
- Archive websites (Wayback Machine)

Active Footprinting - Overview



Direct Target Interaction

Characteristics:

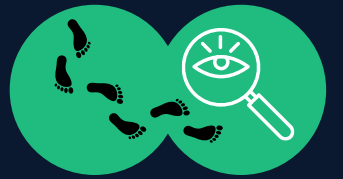
- Requires authorization in ethical hacking
- Leaves traces in target logs
- Provides more accurate and detailed data
- Higher risk of triggering security alerts

Common Techniques:

- Port scanning
- Ping sweeps
- Traceroute mapping
- DNS zone transfer attempts
- Banner grabbing
- Social engineering calls

 **Warning:** Always obtain written permission before active footprinting.

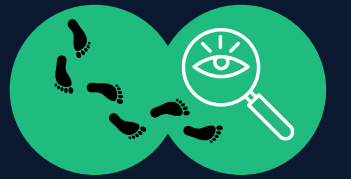
Passive vs Active Footprinting



Aspect	Passive Footprinting	Active Footprinting
Definition	Simulate attacks on systems to find vulnerabilities	Directly interacting with target systems
Detection Risk	✗ Very Low / Undetectable	⚠ High / Easily detected
Legal Concerns	☑ Generally legal (public info)	⚠ May require authorization
Examples	Google searches, WHOIS, Social media, public records	Port scanning, Ping sweeps, DNS zone transfer attempts
Information Depth	Moderate - Surface level	Deep - Detailed technical info
Tools	Search engines, Maltego, theHarvester	Nmap, Netcat, traceroute

Best Practice: Always start with passive reconnaissance. Only move to active when necessary and authorized!

Search Engines - The First Tool



Leveraging Search Engines for Recon

Why Search Engines?

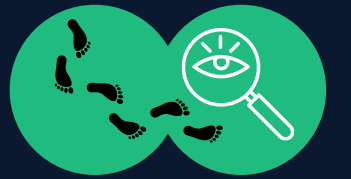
- Massive indexed information
- Can reveal sensitive data unintentionally exposed
- Free and easy to use
- Multiple search engines provide different results

Popular Search Engines:

- Google (most comprehensive)
- Bing (Microsoft's alternative)
- DuckDuckGo (privacy-focused)
- Baidu (Chinese content)
- Yandex (Russian content)

Tip: Use multiple search engines as each indexes content differently.

Google Dorking - Introduction



Advanced Search Operators

What is Google Dorking? Using advanced search operators to find specific information that regular searches might miss.

Why it matters:

- Exposes sensitive files and directories
- Finds misconfigured websites
- Discovers vulnerable systems
- Locates confidential documents

Common Operators:

- site: - Search within a specific domain
- filetype: - Find specific file types
- intitle: - Search in page titles
- inurl: - Search in URLs
- intext: - Search in page content
- cache: - Google's cached version

Google Dorking - Practical Examples

Real-World Search Queries

Finding exposed files:

- `site:mmu.edu.my filetype:pdf confidential`
- `intitle:"index of" backup`
- `filetype:xls username password`

Finding vulnerable systems:

- `inurl:admin intitle:login`
- `intitle:"Apache Status" "Apache Server Status for"`
- `inurl:8080 -intext:8080`
- `cache:example.com`
- `intitle:"Apache Tomcat" "Error" inurl:phpinfo.php`
- `intitle:"phpMyAdmin" "Welcome to phpMyAdmin"`

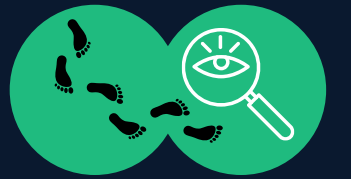
Finding configuration files:

- `filetype:env DB_PASSWORD`
- `ext:conf intext:password`
- `filetype:ovpn`

 **CRITICAL:** Only use Google Dorking on domains you're authorized to test! Accessing exposed files without permission is illegal.

Resource: Google Hacking Database (exploit-db.com/google-hacking-database)

Modern Tools - DorkGPT



AI-Assisted Reconnaissance

DorkGPT (dorkgpt.com):

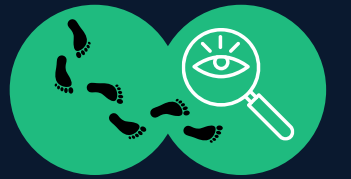
- AI-powered tool for generating Google dorks
- Simplifies complex query creation
- Helps discover creative search patterns

How it works:

1. Describe what information you're looking for
2. DorkGPT generates appropriate search queries
3. Use generated queries in search engines
4. Refine results based on findings

Example: "Find exposed database backup files on educational institutions" → Generates: `site:edu filetype:sql "backup" OR "dump"`

WHOIS Lookups



Domain Registration Intelligence

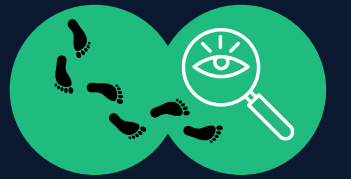
What is WHOIS? A public database containing domain registration information.

Information You Can Find:

- Domain owner (registrant name/organization)
- Registration and expiration dates
- Registrar information
- Administrative and technical contacts
- Email addresses
- Phone numbers
- Physical addresses
- Name servers

Note: Privacy protection services may redact personal information, but organizational details often remain visible.

WHOIS - Practical Use



Performing WHOIS Lookups

What is WHOIS? A public database containing domain registration information.

Online & Desktop Tools:

- whois.domaintools.com
- who.is
- icann.org/whois
- Sam Spade (Windows and UNIX only)

Command Line:

- Linux/Mac: `whois example.com`
- Windows: Download Sysinternals WHOIS utility

What to Look For:

- Contact emails (for phishing campaigns)
- Associated domains owned by same entity
- Name server information (DNS infrastructure)
- Registration patterns (date ranges)
- Organizational details

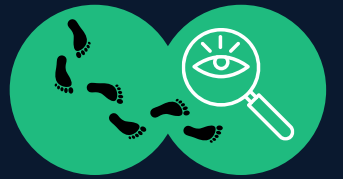
The screenshot shows the DomainTools website interface. At the top, there's a navigation bar with links for PROFILE, CONNECT, MONITOR, and SUPPORT, along with a 'Whois Lookup' search bar. The main content area is titled 'Whois Record for Mmu.edu.my'. Below this, there's a 'Domain Profile' section with a table of domain details. The table includes fields like Registrar (MYNIC Berhad), Registrar Status (ok), Dates (9,644 days old, Created on 1999-06-23, Expires on 2026-06-23, Updated on 2025-07-22), Name Servers (NS1.A0.IMPERVASECUREDNS.NET, NS1.A1.IMPERVASECUREDNS.NET, NS1.A2.IMPERVASECUREDNS.NET), IP Address (45.60.11.220), IP Location (Washington - Seattle - Incapsula Inc), ASN (AS19551 INCAPSULA, US), IP History (3 changes on 3 unique IP addresses over 2 years), and Hosting History (1 change on 2 unique name servers over 0 year). At the bottom, there's a 'Whois Record' section with a text block containing raw WHOIS data for the domain mmu.edu.my, including registry ID, registrar URL, creation and expiry dates, and contact information.

Domain Profile	
Registrar	MYNIC Berhad IANA ID: 999000002 URL: https://whois.mynic.my Whois Server: whois.mynic.my abuse@mynic.my
Registrar Status	ok
Dates	9,644 days old Created on 1999-06-23 Expires on 2026-06-23 Updated on 2025-07-22
Name Servers	NS1.A0.IMPERVASECUREDNS.NET (has 7,134 domains) NS1.A1.IMPERVASECUREDNS.NET (has 7,134 domains) NS1.A2.IMPERVASECUREDNS.NET (has 7,134 domains)
IP Address	45.60.11.220 - 6 other sites hosted on this server
IP Location	- Washington - Seattle - Incapsula Inc
ASN	AS19551 INCAPSULA, US (registered Jan 12, 2011)
IP History	3 changes on 3 unique IP addresses over 2 years
Hosting History	1 change on 2 unique name servers over 0 year

Whois Record (last updated on 2025-11-17)

```
Domain Name: mmu.edu.my
Registry Domain ID: D5A000024-MYNIC
Registrar WHOIS Server: whois.mynic.my
Registrar URL: https://whois.mynic.my
Updated Date: 2025-07-22T14:40:11.172Z
Creation Date: 1999-06-23T16:00:00.000Z
Registry Expiry Date: 2026-06-23T16:00:00.000Z
Registrar: MYNIC Berhad
Registrar IANA ID: 999000002
Registrar Abuse Contact Email: abuse@mynic.my
Registrar Abuse Contact Phone:
```

DNS Fundamentals



Domain Name System Basics

What is DNS (Domain Name System)? The "phonebook" of the Internet - translates human-readable domain names to IP addresses. It's a treasure trove of information for reconnaissance.

Key DNS Components:

- **Domain Name:** example.com
- **Name Server:** Server that answers DNS queries
- **DNS Records:** Different types of information stored
- **Zones:** Administrative divisions of DNS namespace

Why DNS Matters in Recon:

- Reveals network infrastructure
- Shows associated services (mail, web)
- Can expose internal systems
- May have security misconfigurations

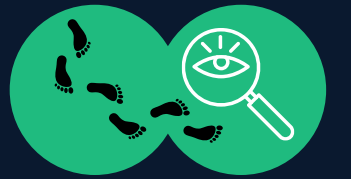
DNS Record Types



Common DNS Record Types:

Record Type	Purpose	Recon Value	Examples:
A	Maps domain to IPv4 address	Identify server IPs	www.example.com → 192.168.1.100
AAAA	Maps domain to IPv6 address	IPv6 infrastructure discovery	www.example.com → 2001:0db8:85a3::8a2e:0370:7334
MX	Mail exchange servers	Email server locations, potential phishing targets	example.com → mail.example.com
NS	Name servers for domain	DNS infrastructure	example.com → ns1.dns-provider.com
TXT	Text information	SPF records, verification codes, sometimes sensitive info	v=spf1 ip4:192.0.2.1 include:_spf.example.com ~all
CNAME	Canonical name (alias)	Subdomain relationships	blog.example.com → webserver.example.com
SOA	Start of Authority	Primary DNS server, admin email	example.com. 900 IN SOA ns1.example.com.
SRV	Service locator for specific services	Provide significant value during network reconnaissance	_service._proto.name. TTL class type priority weight port target.

DNS Query/Enumeration Tools



Performing DNS Lookups

Command Line Tools:

nslookup:

- nslookup example.com
- nslookup -type=mx example.com

dig (Linux/Mac):

- dig example.com
- dig example.com MX
- dig example.com ANY

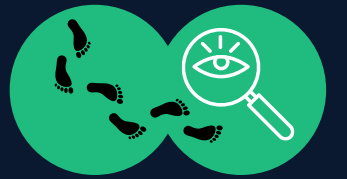
host (Linux):

- host example.com
- host -t mx example.com

Online Tools:

- DNSDumpster.com
- MXToolbox.com
- ViewDNS.info

DNS Zone Transfer Vulnerability



What is a DNS Zone? A portion of the DNS namespace managed by a specific name server.

DNS Zone Transfer (AXFR) is a mechanism to replicate DNS databases between name servers. If misconfigured, it can leak the entire DNS zone file!

What Information is Leaked?

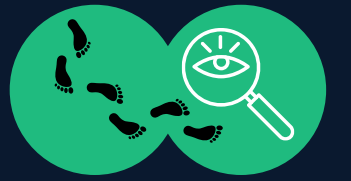
- Complete list of subdomains (mail.example.com, vpn.example.com, etc.)
- Internal server names (might reveal naming conventions)
- IP addresses of all systems
- Network topology insights

How to Test for Zone Transfer:

```
# Using dig dig axfr @nameserver example.com
# Using host host -t axfr example.com nameserver
# Using nslookup nslookup > server nameserver > set
type=any > ls -d example.com
```

Security Issue: Zone transfers should only be allowed between trusted DNS servers, not from arbitrary internet hosts. This is a common misconfiguration!

DNS Zone Transfer - Attack



Attempting Zone Transfer

Using dig command:

```
dig @ns.example.com example.com axfr
```

Using host command:

```
host -l example.com ns.example.com
```

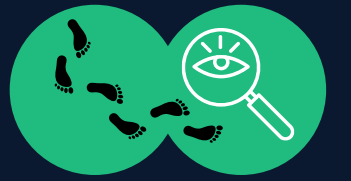
What You Get (if successful):

- All A records (every server IP)
- All subdomains
- Internal naming conventions
- Network organization
- Service locations (mail, FTP, VPN, etc.)

Example Output:

- www.example.com → 192.168.1.10
- mail.example.com → 192.168.1.20
- vpn.example.com → 192.168.1.30
- internal.example.com → 10.0.0.5

DNS Zone Transfer - Prevention



Securing DNS Servers

Mitigation Strategies:

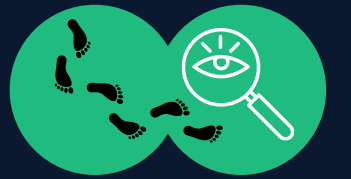
1. Configure DNS servers to allow zone transfers only from specific IPs
2. Use TSIG (Transaction Signatures) for authentication
3. Implement access control lists (ACLs)
4. Regular security audits of DNS configurations
5. Monitor DNS query logs for suspicious activities

Configuration Example (BIND):

```
allow-transfer { 192.168.1.2; 192.168.1.3; };
```

Testing Your Own DNS: Always test your organization's DNS servers for this vulnerability.

Shodan - The IoT Search Engine



Searching for Connected Devices

What is Shodan? A search engine that scans the entire internet for connected devices and services.

What Shodan Reveals:

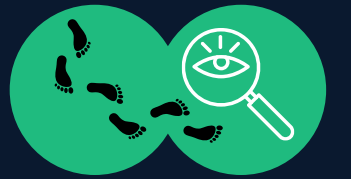
- Open ports on servers
- Running services and versions
- Software banners
- Default credentials
- Webcams, routers, industrial systems
- Vulnerabilities in exposed systems

Example Searches:

- port:3389 country:MY (RDP servers in Malaysia)
- apache 2.4.49 (specific Apache version)
- "default password" (devices with default credentials)

Website: shodan.io

Shodan - Use Cases



Practical Applications

For Security Professionals:

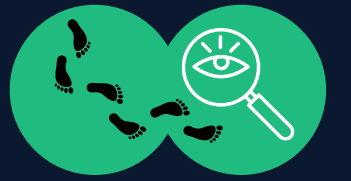
- Identify exposed organizational assets
- Find misconfigured devices
- Discover shadow IT
- Asset inventory verification
- Vulnerability assessment

Information You Can Extract:

- Server locations (geographical)
- Operating systems
- Software versions
- Open ports and services
- SSL certificate information
- Historical data on systems

 **Warning:** Free accounts have limited searches. Paid accounts offer more features.

Web Footprinting - robots.txt



What Websites Try to Hide

What is robots.txt? A file that tells search engine crawlers which pages or directories NOT to index.

Why It Matters:

- Often reveals sensitive directories
- Shows admin panels, backup locations
- Indicates areas of concern to administrators

How to Access:

Simply visit: <http://example.com/robots.txt>

(Note: Replace example.com with the real website name)

Example Content:

User-agent: *

Disallow: /admin/

Disallow: /backup/

Disallow: /private/

Disallow: /logs/

Disallow: /config/

Red Flag: These "hidden" directories become prime targets for attackers.

Web Footprinting - Additional Techniques

More Website Intelligence

Examining HTTP Headers:

- Reveal web server type and version
- Show programming frameworks
- Expose security headers (or lack thereof)
- Tool: Browser developer tools, curl, Netcat

Analyzing Cookies:

- Session management methods
- Third-party tracking
- Potential vulnerabilities
- Tool: Browser developer tools, Cookie Editor extensions

BuiltWith (builtwith.com): Technology profiler for websites

- CMS detection (WordPress, Drupal)
- JavaScript libraries and frameworks
- Analytics and tracking tools
- Hosting providers

Censys (censys.io): Search engine for Internet assets and devices

- Certificate transparency monitoring
- Subdomain discovery
- Similar to Shodan but with different data

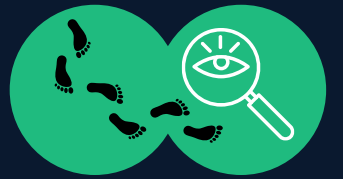
Web Archives:

- Wayback Machine (archive.org)
- See historical website versions
- Find removed content
- Discover old vulnerabilities or configurations

HTML Source Code:

- Hidden comments
- Developer notes
- API endpoints
- Internal paths

Email Footprinting/Enumeration



Email-Based Intelligence

Email addresses are valuable for phishing attacks, password spraying, and social engineering.

Finding Email Addresses:

- Company websites (Contact Us pages)
- WHOIS records
- Social media profiles
- Public documents (PDFs often contain metadata)
- LinkedIn profiles

Why Email Addresses Matter:

- Enable targeted phishing attacks
- Potential usernames for systems
- Organizational structure insights
- Social engineering targets

Techniques for Finding Emails:

- **theHarvester:** Automated email scraping from multiple sources
- **Hunter.io:** Email finder and verifier service
- **LinkedIn:** Manual enumeration of employees
- **Company websites:** Contact pages, team pages
- **GitHub commits:** Developers often use work emails
- **WHOIS records:** Administrative contacts

Email Format Discovery (Common formats to test):

- firstname.lastname@company.com
- firstname@company.com
- firstnamelastname@company.com
- f.lastname@company.com
- firstname.l@company.com

Using HTTP Basics

HTTP, or Hypertext Transfer Protocol, is the foundational set of rules that governs communication between web browsers and web servers for data exchange on the web.

HTTP operates on port 80

- Use HTTP language to pull information from a Web server
- Basic understanding of HTTP is beneficial for security testers
- Return codes
 - Reveal information about server OS

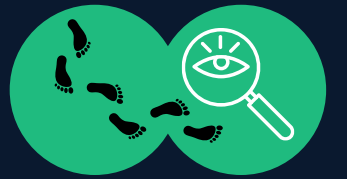
Error	Description
400 Bad Request	Request not understood by server
401 Unauthorized	Request requires authentication
402 Payment Required	Reserved for future use
403 Forbidden	Server understands request but refuses to comply
404 Not Found	Unable to match request
405 Method Not Allowed (methods are covered later in this section)	Request not allowed for the resource
406 Not Acceptable	Resource does not accept your request
407 Proxy Authentication Required	Client must authenticate with proxy
408 Request Timeout	Request not made by client in allotted time
409 Conflict	Request could not be completed due to an inconsistency
410 Gone	Resource is no longer available
411 Length Required	Content length not defined
412 Precondition Failed	Request header fields evaluated as false
413 Request Entity Too Large	Request larger than server is able to process
414 Request-URI (Uniform Resource Identifier) Too Long	Request-URI is longer than the server is willing to accept
500 Internal Server Error	Request could not be fulfilled by server
501 Not Implemented	Server does not support request
502 Bad Gateway	Server received invalid response from upstream server
503 Service Unavailable	Server is unavailable due to maintenance or overload
504 Gateway Timeout	Server did not receive a timely response
505 HTTP Version Not Supported	HTTP version not supported by server

HTTP methods

- GET / HTTP/1.1. is the most basic method
- Can determine information about server OS from the server’s generated output
- Basic method to do banner grab with Telnet (Windows) and Netcat (Unix)

Method	Description
GET	Retrieves data by URI (Uniform Resource Identifier)
HEAD	Same as the GET method, but retrieves only the header information of an HTML document, not the document body
OPTIONS	Requests information on available options
TRACE	Starts a remote application-layer loopback of the request message
CONNECT	Used with a proxy that can dynamically switch to a tunnel connection, such as Secure Socket Layer (SSL)
DELETE	Requests that the origin server delete the identified resource
PUT	Requests that the entity be stored under the Request-URI
POST	Allows data to be posted (that is, sent to a Web server)

Other Methods of Gathering Information



Detecting Cookies and Web Bugs

Cookies are small files that websites store on a user's browser to remember information about their visit, making the experience easier and more personalized, and helps to improve the performance on the subsequent visits.

Cookies

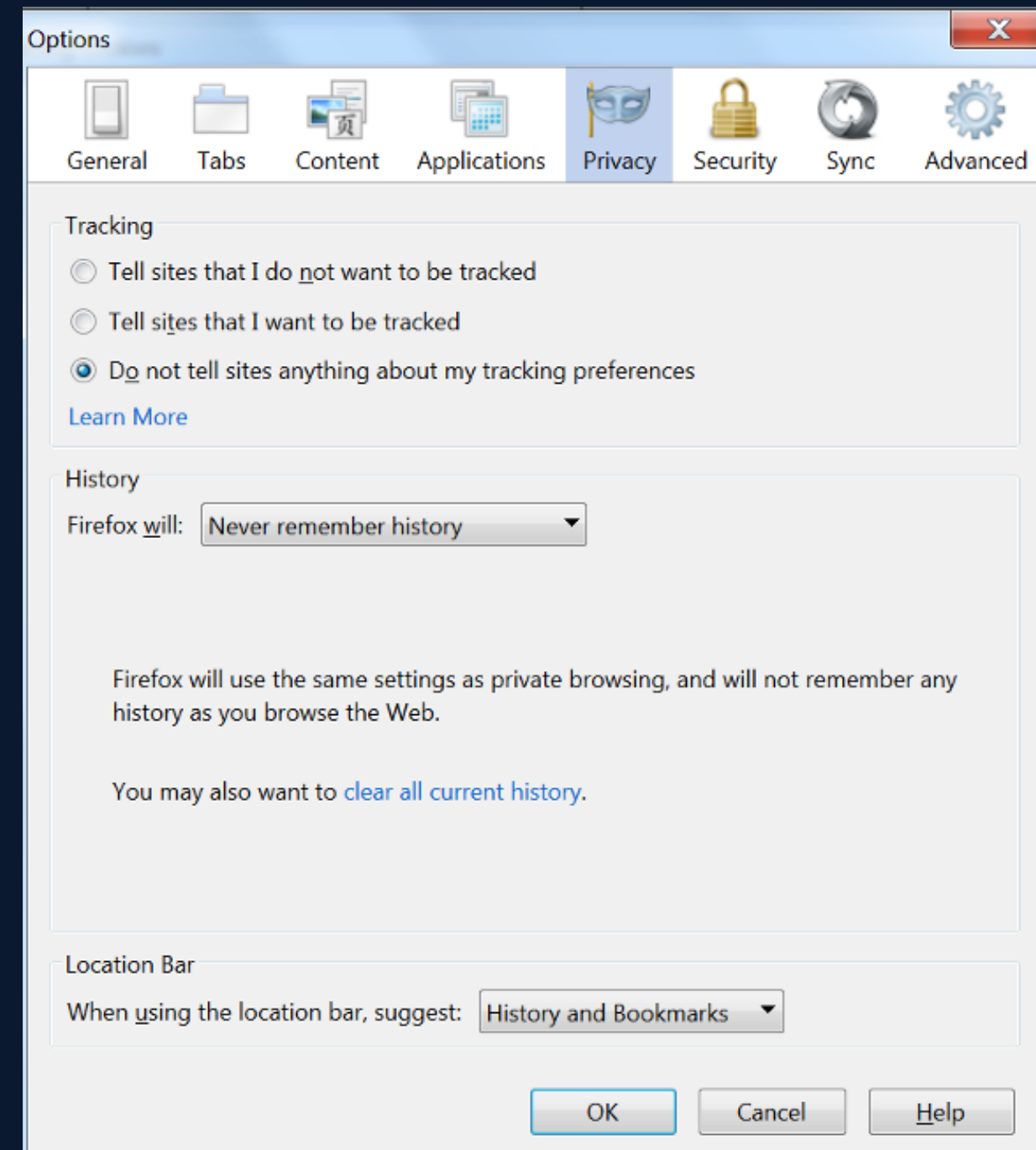
- Text file generated by a Web server
- Stored on a user's browser (make sure clear your cookies of your PC)
- Information sent back to Web server when user returns
- Some cookies store personal information
- Create security issue

Viewing Cookies

- In Firefox
- Tools, Options
- Privacy tab
- Show Cookies

Web bug

- 1-pixel x 1-pixel image file (usually transparent)
- Referenced in an tag
- Usually works with a cookie
- Purpose similar to that of spyware and adware
- Comes from third-party companies specializing in data collection



OSINT (Open-Source Intelligence)

OSINT is intelligence collected from publicly available sources. In cybersecurity, it's used to gather information about targets from open sources.

OSINT Sources:

Traditional Sources:

- Search engines (Google, Bing, Yandex)
- Company websites
- Public records, government, and court databases
- Job postings (reveal tech stack!)
- News articles and press releases
- Financial reports (public companies)

Modern Sources:

- Social media (LinkedIn, X, Facebook, Instagram)
- GitHub repositories (leaked credentials!)
- Pastebin and similar sites
- Code repositories
- Forums and discussion boards
- Dark web (for breach data)

OSINT Value: People unknowingly share massive amounts of information online. A skilled OSINT analyst can piece together a comprehensive picture of a target from public data alone. **No hacking required and it's generally legal.**

Social Media OSINT

Mining Social Platforms

LinkedIn:

- Employee roles and responsibilities
- Organizational structure
- Technology skills (indicates tech stack)
- Job postings (reveal systems used)
- Company size and growth

Facebook/Instagram:

- Personal information about employees
- Location data (geotagging)
- Relationships and connections
- Schedules and routines
- Photos revealing sensitive information

X:

- Real-time updates
- Employee complaints (security issues)
- Technology discussions
- Conference attendance

Red Flags Employees Share:

- Vacation announcements (physical security)
- Work-from-home setups (visible screens)
- Company badges in photos
- Internal documents in the backgrounds

Real Case: MGM Resorts breach (2023) started with LinkedIn OSINT. Attackers identified IT help desk employees and impersonated them via phone call to gain VPN access.

Metadata in Documents

Hidden Information in Files

What is Metadata? Data about data - information embedded in files that describes the file itself.

Metadata in Documents Can Reveal:

- Author names
- Organization names
- Computer/username used for creation
- Software versions
- Edit history and track changes
- File creation and modification dates
- Internal file paths
- GPS coordinates (in photos)

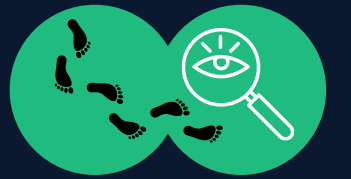
Common File Types:

- Microsoft Office (.docx, .xlsx, .pptx)
- PDFs
- Images (JPEG, PNG)
- Audio/Video files

Tools to Extract Metadata:

- ExifTool
- FOCA (Fingerprinting Organizations with Collected Archives)
- Metagoofil

Maltego - Visual OSINT Framework



Maltego is a powerful OSINT and graphical link analysis tool used for gathering and connecting information about targets.

Maltego Capabilities:

- **Visual relationship mapping:** See connections between entities
- **Transforms:** Automated queries that gather data from various sources
- **Entity types:** Domains, IPs, emails, phone, social media, organizations connections, network infrastructure
- **Data correlation:** Link disparate pieces of information
- **Export options:** Save graphs and reports

Common Maltego Transforms:

Domain Transforms:

- DNS from domain
- Email from domain
- To IP addresses
- To netblocks

Person Transforms:

- To email addresses
- To phone numbers
- To social media profiles
- To documents

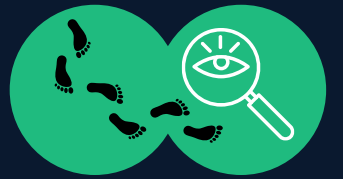
Organization Mapping:

- Company structure
- Employee connections
- Technology infrastructure
- Digital footprint

Output: Visual graph showing all connections and relationships.

Maltego CE (Community Edition): Free version with limited transforms. Sufficient for learning and basic OSINT work.

theHarvester Tool



Email and Subdomain Enumeration

theHarvester is an OSINT command-line tool designed to gather emails, subdomains, IPs, and URLs from public sources.

Data Sources Used by theHarvester:

- Search engines (Google, Bing, Baidu, DuckDuckGo), LinkedIn, X, Shodan, Certificate transparency logs, Threat intelligence platforms, PGP Key Servers, Github, VirusTotal, DNS enumeration, Netcraft etc.

Common Maltego Transforms:

Basic Usage:

```
theHarvester -d example.com -b google
theHarvester -d example.com -b all
theHarvester -d example.com -b linkedin
```

Output:

- Email addresses found
- Subdomains discovered
- Associated hostnames
- IP addresses

Running a Step-by-Step Scan:

1. Install theHarvester (usually pre-installed in Kali Linux at: `/usr/bin/theHarvester`)

2. Basic scan with bash command:

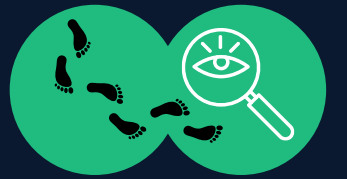
- `theHarvester -d mmu.edu.my -b google -l 200`
 - `-d`: target domain, `-b`: data source, `-l`: limit number of results

1. Comprehensive scan with bash command:

- `theHarvester -d mmu.edu.my -b all -f output.html`
 - `-b all`: use all sources, `-f`: save output to file

Analysis: Review discovered emails for phishing targets, Map subdomains for further reconnaissance, Identify potential attack surfaces

Additional OSINT Tools



Expanding Your Toolkit

Tools	Descriptions/Features
Recon-ng	• Modular web reconnaissance framework • Similar to Metasploit in structure • Automated information gathering
Spiderfoot	• Automated OSINT tool • 200+ modules for data collection • Web-based interface
FOCA (Windows)	• Metadata extraction • Document fingerprinting • Network infrastructure discovery
Sublist3r	• Fast subdomain enumeration • Multiple source integration • Simple to use

Website: Each tool has official documentation and GitHub repositories.

Netcraft Site Report - Web Server Intelligence

Netcraft an online tool provides detailed information about websites including hosting history, technology stack, and security posture.

Information Provided:

- Web server software and version (Apache, Nginx, IIS)
- Operating system
- Hosting provider
- Technology stack
- Site uptime history
- SSL/TLS certificate details
- Historical DNS records
- Hosting location
- Subdomain discovery
- IP address, netblock and changes

Use Cases:

- Identify outdated software versions
- Find technology vulnerabilities
- Understand hosting infrastructure
- Track website changes over time

Usage:

Web Interface

<https://sitereport.netcraft.com/?url=example.com>

Shows detailed site report including: - Background, Network, Hosting History - SSL/TLS configuration - Site technology - Subdomains found

Free Service: Netcraft Site Report is completely free and doesn't require registration. Excellent for quick reconnaissance.

Website: netcraft.com

Certificate Transparency Logs

What are CT Logs? Public logs of all SSL/TLS certificates issued by Certificate Authorities.

Why They're Useful:

- Discover subdomains not found elsewhere
- Find internal hostnames
- Identify recently added infrastructure
- Track certificate history

Tools to Search CT Logs:

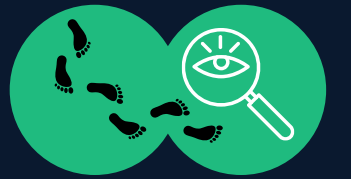
- crt.sh (most popular)
- censys.io
- Google Certificate Transparency

Example Search: Search `%.example.com` on crt.sh to find:

- api.example.com
- staging.example.com
- dev.example.com
- internal.example.com

Advantage: Cannot be hidden like DNS records can.

Subdomain Enumeration



Subdomains often host development servers, admin panels, APIs, and other less-secured systems.

Why Subdomains Matter:

- **Expanded attack surface:** More systems = more potential vulnerabilities
- **Forgotten systems:** Old dev/staging servers may be unpatched
- **Different security posture:** Main site secure, but dev.example.com is not
- **Information disclosure:** Test/staging environments may leak data

Subdomain Discovery Tools:

```
# theHarvester theHarvester -d example.com -b all
```

```
# Sublist3r sublist3r -d example.com
```

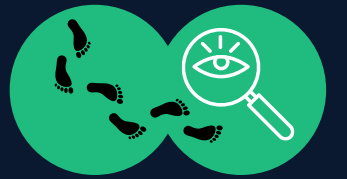
```
# Amass (advanced) amass enum -d example.com
```

```
# Certificate Transparency (crt.sh) curl -s "https://crt.sh/?q=%.example.com&output=json" | jq
```

```
# DNS Brute Force dnsrecon -d example.com -t brt -D /usr/share/wordlists/dnsmap.txt
```

Common Subdomain Patterns: www, mail, ftp, admin, dev, test, staging, api, vpn, remote, portal, blog, shop, support

Introduction to Social Engineering



Social Engineering is the psychological manipulation of people into performing actions or divulging confidential information.

Why Social Engineering is Effective:

- **Human nature:** People want to be helpful
- **Authority:** People follow instructions from perceived authority figures
- **Urgency:** Time pressure bypasses critical thinking
- **Trust:** People trust others by default
- **Curiosity:** People want to know secrets

Connection to Footprinting: Information gathered during footprinting makes social engineering attacks more convincing and effective.

Common Techniques:

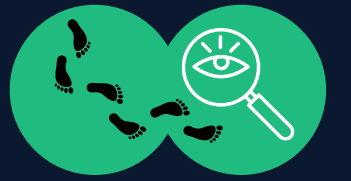
- **Phishing:** Fake emails
- **Vishing:** Voice phishing (phone)
- **Smishing:** SMS phishing
- **Pretexting:** Creating false scenarios
- **Baiting:** Offering something enticing
- **Tailgating:** Physical access

Recon Connection: Information gathered during reconnaissance makes social engineering much more effective:

- Employee names and titles
- Email formats
- Company structure
- Technology used
- Recent news/events

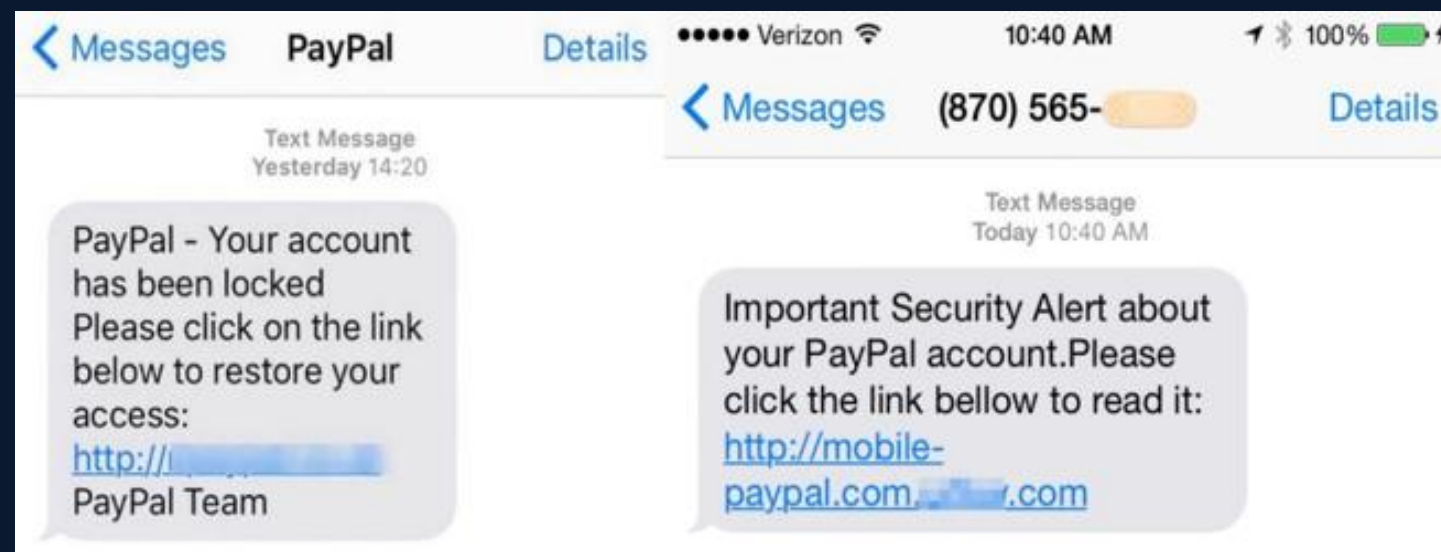
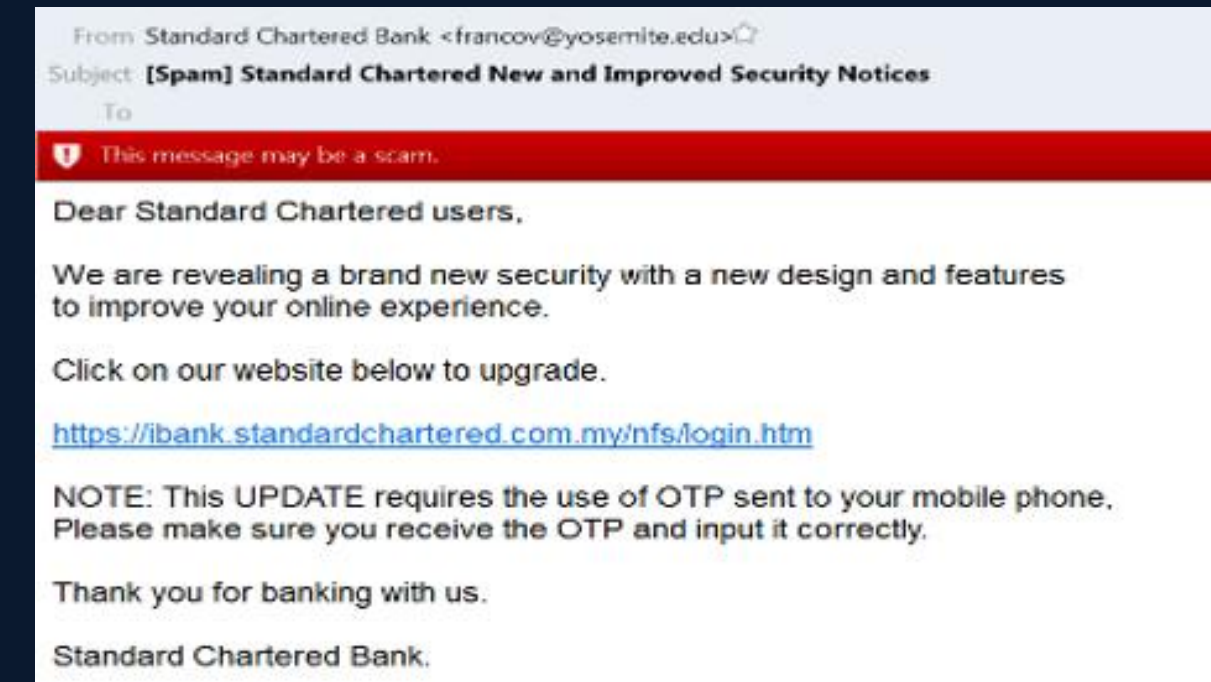
Key Point: The best technical security is useless if humans can be manipulated to bypass it.

Social Engineering Psychological Principles

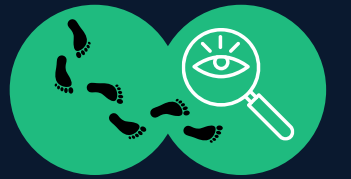


How Attackers Manipulate and some Examples

Key Techniques	Details
Authority Impersonating figures of power	"This is IT Director calling..." - Using company titles - Urgency from "management"
Reciprocity Give something to get something	- Offer help first - Small favors create obligation
Social Proof People follow others	- Everyone else already submitted..." "Your colleagues have already..."
Scarcity Creating urgency	"Limited time to respond" "Account will be closed"
Liking/Friendship Build rapport	- Common interests - Friendly conversation - Appear trustworthy



Systematic Reconnaissance Methodology



Step-by-Step Recon Process:

- **Step 1: Define Scope**
 - Clearly understand what you're authorized to investigate
- **Step 2: Passive Reconnaissance**
 - WHOIS lookup → Domain registration info
 - DNS enumeration → Subdomains, mail servers, name servers
 - Google dorking → Exposed files, directories
 - Social media → Employee info, company structure
 - theHarvester → Emails, IPs, subdomains
 - Netcraft → Technology stack, hosting info
- **Step 3: Organize Information**
 - Use tools like Maltego to visualize relationships and connections
- **Step 4: Validate Findings**
 - Cross-reference information from multiple sources
- **Step 5: Document Everything**
 - Keep detailed notes for reporting and future reference

Operational Security (OPSEC) During Recon

Even during passive reconnaissance, you leave traces. OPSEC is about minimizing your digital footprint.

OPSEC Considerations:

What to Protect:

- Your real IP address
- Your identity/location
- Your tools and techniques
- Your client's identity
- Timing patterns

Traces You Leave:

- Web server logs (if you visit target site)
- DNS query logs
- WHOIS lookup logs (some registrars)
- LinkedIn profile views
- Unique search patterns

Protection Methods:

- VPN services
- Tor network (for anonymity)
- VM snapshots
- Burner accounts
- Avoid direct queries to target

Best Practice: For passive recon, use intermediary services (Google cache, Wayback Machine) instead of directly accessing target systems.

Ethical and Legal Boundaries

CRITICAL REMINDERS:

Legal Reconnaissance:

- Public information gathering (Google, social media, WHOIS)
- Using publicly available databases
- DNS queries to public DNS servers
- Accessing publicly indexed web pages
- Reading job postings and company websites

Illegal/Grey Area Activities:

- Accessing non-public information without permission
- Creating fake profiles to gather information (impersonation)
- Social engineering without authorization
- Brute-forcing or password guessing
- Exploiting any vulnerabilities found
- Aggressive subdomain bruteforcing (may be detected as attack)

Golden Rule: If you're unsure whether something is legal, ask your instructor or don't do it. For assignments, only use instructor-provided test domains.

Case Study: Recon Leading to Breach

Target: Major Financial Institution (2023)

Attack Timeline:

1. Phase 1 - OSINT (2 weeks):

- LinkedIn enumeration: Identified 200+ employees
- Job postings revealed Cisco VPN and Microsoft AD
- Email format confirmed: firstname.lastname@bank.com
- GitHub search found old config files with server naming convention

2. Phase 2 - Subdomain Discovery:

- Found forgotten subdomain: old-vpn.bank.com
- Running outdated Cisco VPN version with known CVE

3. Phase 3 - Social Engineering:

- Targeted IT help desk employee via LinkedIn info
- Crafted convincing pretext about VPN access issues
- Obtained valid credentials

4. Result:

- Initial access gained through reconnaissance findings
- \$50M+ in losses
- Customer data compromised

Lesson: 80% of the successful attack was due to thorough reconnaissance. No zero-day exploits needed - just publicly available information weaponized effectively.

Key Takeaways from Week 2

1. Reconnaissance is the foundation

Spend 70-80% of time gathering information before attempting exploitation

2. Start passive, move to active carefully

Passive recon is safer and legal; active recon requires authorization

3. Information is everywhere

Social media, job postings, GitHub, and public records contain valuable data

4. Tools automate, but manual analysis is crucial

Use tools like theHarvester and Maltego, but manually verify and correlate findings

5. Ethics and legality are non-negotiable

Only gather information from public sources; respect privacy and authorization boundaries

Thank You

ANY QUESTIONS?

